

MySQL Service Enumeration and Security Assessment

Author: Sudip Bastola

Target System: Metasploitable 2 Linux VM (192.168.83.131)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 24, 2026

Executive Summary

A security assessment was performed targeting the MySQL service available in the Metasploitable 2 VM within a laboratory setting.

The purpose of the assessment was to ascertain if the database service can be remotely accessed, discover any exposed databases, enumerate the database users, and determine the permissions assigned to the authenticated user.

Remotely authenticated connection to the MySQL service was achieved through the use of valid credentials. After authenticating to the MySQL service, some databases were discovered. The assessment revealed that the database account had full administrative permissions on the MySQL server.

Risk Summary Matrix

Metric	Details
Risk Rating	High
Vulnerability	Weak Authentication/ Excessive Database Privileges
Service	MySQL 5.0.51a
Port	TCP/3306
Authentication	Successful
Database Privilege	Full Administrative (All Privileges)
Operating System Access	Not Assessed

Scope and Methodology

The assessment followed a structured penetration testing methodology consisting of:

- Host Discovery
- Service Enumeration
- Authentication
- Database Enumeration
- Privilege Assessment

Technical Findings

Finding: Remote MySQL Authentication and Privilege Enumeration

Step1. Host Discovery

Objective: Identify active hosts within the laboratory network.

Command: nmap -sn <Target IP>

```
[root@kali]~# nmap -sn 192.168.83.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 21:20 +0545
Nmap scan report for 192.168.83.1
Host is up (0.00038s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.83.2
Host is up (0.00022s latency).
MAC Address: 00:50:56:E8:C0:9E (VMware)
Nmap scan report for 192.168.83.131
Host is up (0.0016s latency).
MAC Address: 00:0C:29:79:6F:6F (VMware)
Nmap scan report for 192.168.83.254
Host is up (0.0011s latency).
MAC Address: 00:50:56:FB:E2:F1 (VMware)
Nmap scan report for 192.168.83.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.97 seconds
```

Step2. Service Enumeration

Objective: Identify MySQL service and determine its version.

Command: `nmap -sC -p 3306 <Target IP>`

```
(root@kali)-[/home/sudip]
# nmap -sV -p 3306 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 21:20 +0545
Nmap scan report for 192.168.83.131
Host is up (0.00080s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5
MAC Address: 00:0C:29:79:6F:6F (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.12 seconds
```

Step3. Remote Authentication

Objective: Authenticate to the MySQL service.

Command: `mysql -h <Target-IP> -u root -p --skip-ssl`

Result: A successful remote connection to the MySQL server was established using valid credentials.

```
(root@kali)-[/home/sudip]
# mysql -h 192.168.83.131 -u root -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 9
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
```

Step4. Database Enumeration

Command: SHOW DATABASES;

Result: The following databases were discovered:

- information_schema
- dvwa
- metasploit
- mysql
- owasp10
- tikiwiki
- tikiwiki195

```
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.001 sec)
```

Step5. User Enumeration

Command: SELECT user, host FROM user;

Result: The following MySQL user accounts were identified.

```
Database changed
MySQL [mysql]> select user ,host from user;
+-----+-----+
| user | host |
+-----+-----+
| debian-sys-maint | % |
| guest | % |
| root | % |
+-----+-----+
3 rows in set (0.001 sec)
```

Step6. Privilege Enumeration

Command: SHOW GRANTS FOR CURRENT_USER();

Result: The account contained data which indicates full administrative privileges within the MySQL database server.

```
MySQL [mysql]> show grants for current_user();
+-----+
| Grants for root@% |
+-----+
| GRANT ALL PRIVILEGES ON *.* TO 'root'@'%' WITH GRANT OPTION |
+-----+
1 row in set (0.001 sec)
```

Security Impact

Successful authentication with administrative database privileges could allow attacker to :

- Read database contents
- Modify existing records
- Create or delete databases
- Manage user accounts
- Grant privileges to other database users
- Alter database configuration

Remediation and Recommendations

Immediate Actions

- Disable remote root authentication.
- Replace weak/default credentials with strong passwords.
- Restrict MySQL access to trusted hosts only.
- Remove unnecessary database accounts.

Long Term Security Measures

- Apply current MySQL security updates.
- Enforce least-privilege database access.
- Enable centralized logging and monitoring.
- Perform periodic database security assessments.
- Review user privileges regularly.

Conclusion

The analysis indicated that authentication to the MySQL service was successful, along with the presence of excess administrative privileges. Even though the database service could be accessed through authenticated credentials, there were no attempts to exploit the operating system during this assessment. The results emphasize the significance of proper authentication mechanisms, limited remote access, and the principle of least privilege.

Disclaimer

This assessment was performed in a controlled laboratory environment using Metasploitable 2 for educational purposes. Unauthorized testing of systems without explicit permission is illegal and unethical.